Production Reliability Quick Reference Handbook

DEVOPS ENGINEERING MASTERY — Volume 15, Companion Volume. First Edition, 9 November 2026. Bengali-English glossary (150+ terms), security and SRE command and workflow references, OWASP Top 10 reference, production checklists, troubleshooting decision trees, the competency tracking sheet and official references — keep this beside your terminal. DevSecOps • SRE • Kubernetes Security • SLI/SLO.

বাংলা-ইংরেজি গ্লসারি • টার্ম ১–৬০

গ্লসারি — টার্ম ১–৬০

ইংরেজি টার্মটি **বোল্ডে** দেওয়া আছে, সাথে বাংলা ব্যাখ্যা ও বাস্তব প্রসঙ্গ।

১. DevSecOps — ডেভেলপমেন্ট, নিরাপত্তা ও অপারেশনকে একসাথে জুড়ে দেওয়া চর্চা; নিরাপত্তা শেষে নয়, শুরু থেকেই প্রতিটি ধাপে থাকে।

২. Shift-Left Security — নিরাপত্তা পরীক্ষা ডেভেলপমেন্টের শুরুর দিকে আনা; দেরিতে ধরলে ঠিক করতে খরচ বেশি হয়।

৩. Threat Modeling — সিস্টেমের হুমকি, আক্রমণের পথ ও প্রতিরোধ আগেভাগে চিহ্নিত করার কাঠামোবদ্ধ পদ্ধতি।

৪. STRIDE — Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — হুমকি শ্রেণিবিন্যাসের মডেল।

৫. OWASP Top 10 — ওয়েব অ্যাপের সবচেয়ে গুরুতর ১০টি নিরাপত্তা ঝুঁকির তালিকা; প্রতিটি রিলিজের আগে যাচাই করা উচিত।

৬. Broken Access Control — অনুমতি ছাড়া অন্যের ডেটা বা কাজে পৌঁছে যাওয়া; সার্ভার-সাইডে প্রতিটি রিকোয়েস্ট যাচাই করে ঠিক করা হয়।

৭. Injection (SQLi) — ইনপুটকে কোড হিসেবে চালিয়ে ডেটাবেস বা সিস্টেমে অননুমোদিত কাজ করানো; parameterized query দিয়ে প্রতিরোধ করা হয়।

৮. XSS (Cross-Site Scripting) — আক্রমণকারীর স্ক্রিপ্ট অন্য ব্যবহারকারীর ব্রাউজারে চালানো; আউটপুট এনকোডিং ও CSP দিয়ে প্রতিরোধ করা হয়।

৯. CSRF — ব্যবহারকারীর ব্রাউজার দিয়ে তার অজান্তে ক্ষতিকর রিকোয়েস্ট পাঠানো; anti-CSRF টোকেন দিয়ে ঠিক করা হয়।

১০. SSRF — সার্ভারকে দিয়ে অভ্যন্তরীণ সার্ভিসে রিকোয়েস্ট পাঠানো; URL যাচাই ও নেটওয়ার্ক বিভাজন দিয়ে প্রতিরোধ করা হয়।

১১. SAST — Static Application Security Testing; কোড না চালিয়ে সোর্স কোডের দুর্বলতা খোঁজা (যেমন Semgrep)।

১২. DAST — Dynamic Application Security Testing; চলমান অ্যাপকে বাইরে থেকে পরীক্ষা করা (যেমন OWASP ZAP)।

১৩. SCA — Software Composition Analysis; ডিপেন্ডেন্সিতে জানা CVE ও লাইসেন্স ঝুঁকি খোঁজা।

১৪. IAST — Interactive Application Security Testing; চলমান অ্যাপের ভেতর থেকে কোড ও রানটাইম একসাথে দেখে দুর্বলতা ধরা।

১৫. CVE — Common Vulnerabilities and Exposures; প্রতিটি জানা দুর্বলতার সার্বজনীন নম্বর (যেমন CVE-2021-44228)।

১৬. CVSS — Common Vulnerability Scoring System; দুর্বলতার তীব্রতা ০–১০ স্কেলে মাপার পদ্ধতি।

১৭. CWE — Common Weakness Enumeration; দুর্বলতার ধরনের তালিকা (যেমন CWE-89: SQL Injection)।

১৮. SBOM — Software Bill of Materials; সফটওয়্যারের সব উপাদান ও সংস্করণের তালিকা; নতুন CVE এলে দ্রুত প্রভাব জানা যায়।

১৯. SLSA — Supply-chain Levels for Software Artifacts; বিল্ড ও সাপ্লাই চেইনের অখণ্ডতা মাপার ফ্রেমওয়ার্ক।

২০. Sigstore / Cosign — আর্টিফ্যাক্ট স্বাক্ষর ও যাচাইয়ের টুল; ইমেজটি নির্ভরযোগ্য উৎস থেকে এসেছে কি না তা প্রমাণ করে।

২১. Zero Trust — কাউকে ডিফল্টে বিশ্বাস নয়, প্রতিটি অ্যাক্সেস যাচাই করো — এই নীতিতে গড়া নিরাপত্তা মডেল।

২২. Least Privilege — শুধু কাজের জন্য প্রয়োজনীয় ন্যূনতম অনুমতি দেওয়া; অতিরিক্ত অনুমতি ঝুঁকি বাড়ায়।

২৩. Defence in Depth — একাধিক স্তরে প্রতিরক্ষা; একটি স্তর ভাঙলেও অন্যটি রক্ষা করে।

২৪. Secrets Management — API key, পাসওয়ার্ড ও সার্টিফিকেট নিরাপদে সংরক্ষণ, বিতরণ ও rotation-এর ব্যবস্থা (যেমন Vault)।

২৫. Secrets Rotation — সিক্রেট নিয়মিত বদলে দেওয়া; ফাঁস হলেও তার কার্যকারিতার সময়সীমা ছোট থাকে।

২৬. MFA (Multi-Factor Authentication) — পাসওয়ার্ডের সাথে দ্বিতীয় প্রমাণ (যেমন OTP, হার্ডওয়্যার কি) চাওয়া; অ্যাকাউন্ট দখল কঠিন করে।

২৭. RBAC — Role-Based Access Control; ভূমিকা (role) অনুযায়ী অনুমতি দেওয়া, ব্যক্তি অনুযায়ী নয়।

২৮. ABAC — Attribute-Based Access Control; ব্যবহারকারী, রিসোর্স ও প্রসঙ্গের বৈশিষ্ট্য দেখে অনুমতি দেওয়া।

২৯. IAM — Identity and Access Management; কে, কী, কখন অ্যাক্সেস করতে পারবে — তা পরিচালনা করা।

৩০. Policy as Code — নীতি কোড হিসেবে লেখা; সংস্করণ-নিয়ন্ত্রিত, পরীক্ষাযোগ্য ও স্বয়ংক্রিয়ভাবে প্রয়োগযোগ্য।

৩১. OPA (Open Policy Agent) — নীতি মূল্যায়নের ইঞ্জিন; Kubernetes admission control ও অন্যান্য সিদ্ধান্তে ব্যবহৃত হয়।

৩২. Kyverno — Kubernetes-নেটিভ পলিসি ইঞ্জিন; YAML-এ নীতি লিখে Pod-এর নিয়ম প্রয়োগ করা যায়।

৩৩. Admission Controller — Kubernetes-এ রিসোর্স তৈরির অনুরোধ নীতি অনুযায়ী যাচাই করে অনুমোদন বা প্রত্যাখ্যান করা।

৩৪. Pod Security Standards — Kubernetes Pod-এর নিরাপত্তা স্তর: Privileged, Baseline, Restricted।

৩৫. Container Escape — কনটেইনার থেকে বের হয়ে হোস্টে অ্যাক্সেস পাওয়া; privileged কনটেইনার এড়িয়ে প্রতিরোধ করা হয়।

৩৬. Distroless Image — শুধু অ্যাপ ও রানটাইম থাকা ন্যূনতম ইমেজ; শেল ও অপ্রয়োজনীয় টুল না থাকায় আক্রমণ-ক্ষেত্র কমে।

৩৭. Image Scanning — কনটেইনার ইমেজে জানা CVE খোঁজা (যেমন Trivy, Grype); ডেপ্লয়ের আগে ব্লক করা যায়।

৩৮. NetworkPolicy — Kubernetes-এ Pod-এর মধ্যে কোন ট্রাফিক অনুমোদিত তা নির্ধারণ করা; lateral movement কমায়।

৩৯. Service Mesh — মাইক্রোসার্ভিসের মধ্যে ট্রাফিক, mTLS, পর্যবেক্ষণ ও নীতি পরিচালনার স্তর (যেমন Istio, Linkerd)।

৪০. mTLS — Mutual TLS; ক্লায়েন্ট ও সার্ভার দুজনেই একে অপরের পরিচয় যাচাই করে; সার্ভিস-টু-সার্ভিস নিরাপত্তা দেয়।

৪১. WAF — Web Application Firewall; HTTP স্তরে সাধারণ আক্রমণ ফিল্টার করে, তবে নিরাপদ কোডের বিকল্প নয়।

৪২. CSP (Content Security Policy) — ব্রাউজারকে বলে কোন উৎস থেকে স্ক্রিপ্ট চলবে; XSS-এর প্রভাব কমায়।

৪৩. TLS / SSL — পরিবহনে ডেটা এনক্রিপ্ট করার প্রোটোকল; সার্টিফিকেটের মেয়াদ ও নবায়ন পর্যবেক্ষণ করা জরুরি।

৪৪. Encryption at Rest — সংরক্ষিত ডেটা (ডিস্ক, ডেটাবেস, ব্যাকআপ) এনক্রিপ্ট করা; চুরি হলেও পড়া যায় না।

৪৫. Encryption in Transit — নেটওয়ার্কে চলার সময় ডেটা এনক্রিপ্ট করা (TLS); মাঝপথে আড়ি পাতা রোধ করে।

৪৬. Hashing — ডেটাকে একমুখীভাবে নির্দিষ্ট আকারের মানে বদলে দেওয়া; পাসওয়ার্ড সংরক্ষণে ব্যবহৃত হয় (bcrypt/Argon2)।

৪৭. Salting — হ্যাশের আগে পাসওয়ার্ডে এলোমেলো মান যোগ করা; একই পাসওয়ার্ডের হ্যাশও আলাদা হয়।

৪৮. CSPM — Cloud Security Posture Management; ক্লাউড কনফিগারেশন স্ক্যান করে ভুল কনফিগারেশন ও কমপ্লায়েন্স বিচ্যুতি ধরা।

৪৯. CWPP — Cloud Workload Protection Platform; ক্লাউডে চলমান ওয়ার্কলোড (VM, কনটেইনার) রক্ষা করা।

৫০. IaC (Infrastructure as Code) — অবকাঠামো কোড হিসেবে লেখা (Terraform, Helm); সংস্করণ-নিয়ন্ত্রিত ও পুনরুৎপাদনযোগ্য।

৫১. IaC Scanning — Terraform/Helm ফাইলে ভুল কনফিগারেশন ডেপ্লয়ের আগেই ধরা (যেমন Checkov, tfsec)।

৫২. GitOps — গিটকে সত্যের একমাত্র উৎস ধরে ক্লাস্টারের অবস্থা স্বয়ংক্রিয়ভাবে মেলানো (যেমন Argo CD, Flux)।

৫৩. CI/CD — Continuous Integration / Continuous Delivery; কোড একত্র করা, পরীক্ষা ও ডেপ্লয় স্বয়ংক্রিয় করা।

৫৪. Supply Chain Attack — বিশ্বস্ত প্যাকেজ, লাইব্রেরি বা বিল্ড টুলে ক্ষতিকর কোড ঢুকিয়ে অনেক ভুক্তভোগীর কাছে পৌঁছানো।

৫৫. Dependency Pinning — ডিপেন্ডেন্সির নির্দিষ্ট সংস্করণে আটকে রাখা; হঠাৎ ক্ষতিকর আপডেট থেকে রক্ষা পাওয়া যায়।

৫৬. Lockfile — ডিপেন্ডেন্সির সঠিক সংস্করণের তালিকা; সব পরিবেশে একই সংস্করণ নিশ্চিত করে।

৫৭. Provenance — আর্টিফ্যাক্ট কীভাবে, কোথা থেকে ও কে তৈরি করেছে — তার যাচাইযোগ্য রেকর্ড।

৫৮. Attestation — বিল্ড বা আর্টিফ্যাক্ট সম্পর্কে স্বাক্ষরিত দাবি; যাচাই করে বিশ্বাস করা যায়।

৫৯. Vulnerability Management — দুর্বলতা আবিষ্কার, ত্রিয়াজ, প্রতিকার ও যাচাইয়ের ধারাবাহিক চক্র।

৬০. Risk-Based Prioritization — শুধু CVSS স্কোর নয়, শোষণযোগ্যতা, এক্সপোজার ও ব্যবসায়িক প্রভাব মিলিয়ে অগ্রাধিকার ঠিক করা।

বাংলা-ইংরেজি গ্লসারি • টার্ম ৬১–১২০

গ্লসারি — টার্ম ৬১–১২০

৬১. SRE (Site Reliability Engineering) — সফটওয়্যার ইঞ্জিনিয়ারিং দিয়ে অপারেশন সমস্যার সমাধান করে নির্ভরযোগ্য সেবা দেওয়ার চর্চা।

৬২. SLI (Service Level Indicator) — সেবার মানের পরিমাপযোগ্য সূচক, যেমন সফল রিকোয়েস্টের অনুপাত বা লেটেন্সি।

৬৩. SLO (Service Level Objective) — SLI-র লক্ষ্যমান, যেমন ৯৯.৯% রিকোয়েস্ট ৩০০ms-এর মধ্যে সফল হবে।

৬৪. SLA (Service Level Agreement) — গ্রাহকের সাথে চুক্তি; SLO না মানলে কী ক্ষতিপূরণ হবে তা লেখা থাকে।

৬৫. Error Budget — SLO-র অনুমোদিত ব্যর্থতার পরিমাণ (১০০% − SLO); শেষ হলে ফিচার থামিয়ে নির্ভরযোগ্যতায় মনোযোগ দিতে হয়।

৬৬. Burn Rate — Error budget কত দ্রুত খরচ হচ্ছে তার হার; দ্রুত খরচ হলে দ্রুত অ্যালার্ট দেওয়া হয়।

৬৭. Toil — পুনরাবৃত্তিমূলক, ম্যানুয়াল, স্বয়ংক্রিয় করা যায় এমন অপারেশন কাজ; বেশি toil বার্নআউট বাড়ায়।

৬৮. Golden Signals — Latency, Traffic, Errors, Saturation — সেবার স্বাস্থ্য বোঝার চারটি মৌলিক সংকেত।

৬৯. RED Method — Rate, Errors, Duration — রিকোয়েস্ট-ভিত্তিক সার্ভিসের স্বাস্থ্য মাপার পদ্ধতি।

৭০. USE Method — Utilization, Saturation, Errors — প্রতিটি রিসোর্সের স্বাস্থ্য মাপার পদ্ধতি।

৭১. Observability — সিস্টেমের ভেতরের অবস্থা বাইরে থেকে জিজ্ঞাসা করে অজানা সমস্যার কারণ খুঁজে বের করার ক্ষমতা।

৭২. Monitoring — আগে থেকে নির্ধারিত মেট্রিক ও থ্রেশহোল্ড দেখে জানা সমস্যা ধরা।

৭৩. Metrics — সময়ের সাথে সংখ্যায় মাপা মান, যেমন রিকোয়েস্ট সংখ্যা, latency, CPU ব্যবহার।

৭৪. Logs — ঘটনার সময়-ক্রমিক রেকর্ড; তদন্তে কেন ঘটল তা জানা যায়।

৭৫. Traces — একটি রিকোয়েস্টের বিভিন্ন সার্ভিস পেরিয়ে যাওয়ার পথের রেকর্ড; কোথায় সময় গেল তা দেখায়।

৭৬. Span — Trace-এর ভেতরে একটি একক কাজের রেকর্ড; একাধিক span মিলে একটি trace হয়।

৭৭. OpenTelemetry — Trace, metric ও log সংগ্রহের ভেন্ডর-নিরপেক্ষ মান (standard)।

৭৮. Prometheus — মেট্রিক সংগ্রহ ও অ্যালার্টের ওপেন-সোর্স সিস্টেম; PromQL দিয়ে জিজ্ঞাসা করা যায়।

৭৯. PromQL — Prometheus-এর কোয়েরি ভাষা; যেমন error rate বা p95 বের করা যায়।

৮০. Grafana — মেট্রিক ও লগ দেখার ড্যাশবোর্ড টুল; অ্যালার্ট ও ভিজ্যুয়ালাইজেশনে ব্যবহৃত হয়।

৮১. Alert Fatigue — অতিরিক্ত বা অকার্যকর অ্যালার্টে ক্লান্ত হয়ে আসল অ্যালার্টও উপেক্ষা করা; শুধু actionable অ্যালার্ট রাখতে হয়।

৮২. Actionable Alert — যে অ্যালার্টে স্পষ্ট প্রভাব, স্পষ্ট পদক্ষেপ ও runbook থাকে; দেখলেই কী করতে হবে বোঝা যায়।

৮৩. Runbook — একটি পরিচিত সমস্যার ধাপে ধাপে সমাধান নির্দেশিকা; on-call-এর সময় দ্রুত কাজে আসে।

৮৪. On-Call — নির্ধারিত সময়ে ইনসিডেন্টে সাড়া দেওয়ার দায়িত্ব; rotation ও ক্ষতিপূরণসহ পরিচালনা করা উচিত।

৮৫. Incident — সেবা ব্যাহত বা নিরাপত্তা-ঝুঁকির ঘটনা; তীব্রতা অনুযায়ী SEV শ্রেণিতে ভাগ করা হয়।

৮৬. SEV (Severity) — ইনসিডেন্টের তীব্রতা (SEV-1 সবচেয়ে গুরুতর); সাড়ার গতি ও প্রক্রিয়া এতে নির্ধারিত হয়।

৮৭. Incident Commander — ইনসিডেন্টের সময় সমন্বয়, সিদ্ধান্ত ও যোগাযোগের দায়িত্বে থাকা ব্যক্তি।

৮৮. MTTD / MTTR / MTBF — Mean Time To Detect / Recover / Between Failures; নির্ভরযোগ্যতা মাপার সূচক।

৮৯. RCA (Root Cause Analysis) — লক্ষণের পেছনের গভীর কারণ খুঁজে বের করা; 5 Whys একটি কৌশল।

৯০. 5 Whys — বারবার "কেন" জিজ্ঞাসা করে গভীর কারণে পৌঁছানোর কৌশল।

৯১. Blameless Postmortem — দোষ না খুঁজে সিস্টেম ও প্রক্রিয়ার কারণ খোঁজা ইনসিডেন্ট পর্যালোচনা; সত্য তথ্য বের হয়।

৯২. Post-Incident Review — ইনসিডেন্টের পর কী ঘটল, কেন ঘটল ও কী বদলাতে হবে — তার কাঠামোবদ্ধ পর্যালোচনা।

৯৩. Mitigation — রুট কজ ঠিক না হলেও ব্যবহারকারীর ক্ষতি দ্রুত কমানো (যেমন রোলব্যাক, ট্রাফিক সরানো)।

৯৪. Rollback — সমস্যাযুক্ত ডেপ্লয় থেকে আগের সুস্থ সংস্করণে ফেরা।

৯৫. Roll-Forward — পেছনে না ফিরে সামনে একটি ঠিক করা সংস্করণ ডেপ্লয় করে সমস্যা সমাধান করা।

৯৬. Canary Deployment — অল্প ব্যবহারকারীর কাছে নতুন সংস্করণ পরীক্ষা করে ধীরে ধীরে বাড়ানো।

৯৭. Blue-Green Deployment — দুটি পরিবেশ রেখে ট্রাফিক সুইচ করা; রোলব্যাক মানে ট্রাফিক ফিরিয়ে দেওয়া।

৯৮. Rolling Deployment — একবারে কিছু Pod বদলে ধীরে ধীরে পুরো সার্ভিস আপডেট করা।

৯৯. Feature Flag — কোড ডেপ্লয় না করে ফিচার চালু/বন্ধ করার সুইচ; ঝুঁকিপূর্ণ ফিচারের kill switch হিসেবে কাজ করে।

১০০. Circuit Breaker — ব্যর্থ ডিপেন্ডেন্সিতে বারবার রিকোয়েস্ট না পাঠিয়ে দ্রুত fail-fast করার প্যাটার্ন।

১০১. Retry with Backoff — ব্যর্থ রিকোয়েস্ট ধীরে ধীরে বাড়তি বিরতিতে আবার চেষ্টা করা; jitter যোগ করলে thundering herd এড়ানো যায়।

১০২. Load Shedding — অতিরিক্ত লোডে কম গুরুত্বপূর্ণ রিকোয়েস্ট বাদ দিয়ে মূল সেবা রক্ষা করা।

১০৩. Rate Limiting — নির্দিষ্ট সময়ে রিকোয়েস্টের সংখ্যা সীমিত করা; অপব্যবহার ও ব্রুট-ফোর্স থেকে রক্ষা করে।

১০৪. Load Testing — প্রত্যাশিত লোডে সিস্টেমের আচরণ যাচাই করা।

১০৫. Stress Testing — সীমার বাইরে চাপ দিয়ে ভাঙন-বিন্দু ও পুনরুদ্ধার যাচাই করা।

১০৬. Capacity Planning — ভবিষ্যৎ ট্রাফিকের জন্য প্রয়োজনীয় রিসোর্স আগে থেকে পরিকল্পনা করা।

১০৭. Autoscaling (HPA/VPA) — চাহিদা অনুযায়ী Pod-এর সংখ্যা (HPA) বা আকার (VPA) স্বয়ংক্রিয়ভাবে বাড়ানো-কমানো।

১০৮. RTO — Recovery Time Objective; বিপর্যয়ের পর সেবা ফিরতে সর্বোচ্চ কত সময় লাগতে পারে।

১০৯. RPO — Recovery Point Objective; সর্বোচ্চ কত ডেটা হারানো গ্রহণযোগ্য।

১১০. DR (Disaster Recovery) — বড় বিপর্যয়ের পর সেবা ও ডেটা পুনরুদ্ধারের পরিকল্পনা ও অনুশীলন।

১১১. Failover — প্রাইমারি সিস্টেম ব্যর্থ হলে স্বয়ংক্রিয় বা ম্যানুয়ালভাবে বিকল্প সিস্টেমে যাওয়া।

১১২. Backup (3-2-1) — তিন কপি, দুই ধরনের মাধ্যমে, একটি অফসাইট কপি — ব্যাকআপের সোনালি নিয়ম।

১১৩. Chaos Engineering — ইচ্ছাকৃতভাবে ছোট, নিয়ন্ত্রিত ব্যর্থতা ঘটিয়ে সিস্টেমের দুর্বলতা আগেভাগে জানা।

১১৪. Blast Radius — একটি পরীক্ষা বা ব্যর্থতা কতটা বিস্তৃত হতে পারে তার সীমা; ছোট রাখতে হয়।

১১৫. FinOps — ক্লাউড খরচে স্বচ্ছতা, দায়বদ্ধতা ও মূল্য নিশ্চিত করার চর্চা।

১১৬. Right-Sizing — ব্যবহারের মেট্রিক দেখে রিসোর্সের আকার প্রয়োজনের সাথে মেলানো; অতিরিক্ত বড় রিসোর্স খরচ বাড়ায়।

১১৭. Tagging — রিসোর্সে টিম/প্রজেক্ট/পরিবেশের ট্যাগ লাগানো; খরচ কার তা জানার ভিত্তি।

১১৮. DORA Metrics — Deployment frequency, Lead time, Change failure rate, MTTR — ডেলিভারি পারফরম্যান্স মাপার চারটি সূচক।

১১৯. Change Failure Rate — কত শতাংশ পরিবর্তন ইনসিডেন্ট বা রোলব্যাক ঘটায়; বেশি হলে প্রক্রিয়ায় দুর্বলতা আছে।

১২০. Lead Time for Changes — কোড কমিট থেকে প্রোডাকশনে যেতে কত সময় লাগে; কম হলে ডেলিভারি দ্রুত হয়।

বাংলা-ইংরেজি গ্লসারি • টার্ম ১২১–১৮০

গ্লসারি — টার্ম ১২১–১৮০

১২১. Governance — নীতি, দায়িত্ব ও নিয়ন্ত্রণের মাধ্যমে সিস্টেম পরিচালনার কাঠামো; কে কী সিদ্ধান্ত নেবে তা স্পষ্ট করে।

১২২. Compliance — আইন, মান (যেমন GDPR, PCI DSS) ও অভ্যন্তরীণ নীতি মেনে চলা; প্রমাণসহ দেখাতে হয়।

১২৩. SOC 2 — সেবা প্রতিষ্ঠানের নিরাপত্তা, প্রাপ্যতা ও গোপনীয়তা নিয়ন্ত্রণের অডিট কাঠামো।

১২৪. ISO 27001 — তথ্য নিরাপত্তা ব্যবস্থাপনা পদ্ধতির আন্তর্জাতিক মান।

১২৫. GDPR — ইউরোপীয় ব্যক্তিগত ডেটা সুরক্ষা আইন; ডেটা সংগ্রহ, সংরক্ষণ ও ব্যবহারে কঠোর নিয়ম আছে।

১২৬. PCI DSS — পেমেন্ট কার্ড ডেটা রক্ষার মান; কার্ড তথ্য নিয়ে কাজ করলে মানতে হয়।

১২৭. Audit Log — কে, কখন, কী করেছে তার অপরিবর্তনীয় রেকর্ড; তদন্ত ও কমপ্লায়েন্সে ব্যবহৃত হয়।

১২৮. PII (Personally Identifiable Information) — ব্যক্তিকে শনাক্ত করা যায় এমন ডেটা (নাম, ফোন, জাতীয় পরিচয়পত্র নম্বর); লগে মাস্ক করতে হয়।

১২৯. Data Breach — সংবেদনশীল ডেটার অননুমোদিত প্রকাশ বা চুরি; দ্রুত contain ও জানানো দরকার।

১৩০. Incident Response — নিরাপত্তা ঘটনায় সাড়া দেওয়ার পরিকল্পিত প্রক্রিয়া: শনাক্ত, সীমিত, নির্মূল, পুনরুদ্ধার ও শিক্ষা।

১৩১. Containment — ঘটনার প্রভাব ছড়ানো বন্ধ করা; যেমন আক্রান্ত সার্ভার বিচ্ছিন্ন করা।

১৩২. Forensics — ডিজিটাল প্রমাণ সংগ্রহ ও বিশ্লেষণ; কী ঘটেছে তা প্রমাণসহ জানা যায়।

১৩৩. Penetration Testing — অনুমোদিতভাবে আক্রমণকারীর মতো পরীক্ষা করে দুর্বলতা খুঁজে বের করা।

১৩৪. Red Team / Blue Team — Red Team আক্রমণ করে, Blue Team প্রতিরক্ষা করে; একসাথে অনুশীলন করলে প্রতিরক্ষা শক্ত হয়।

১৩৫. Threat Intelligence — আক্রমণকারী, কৌশল ও নতুন হুমকি সম্পর্কে তথ্য; প্রতিরক্ষায় অগ্রাধিকার ঠিক করতে সাহায্য করে।

১৩৬. MITRE ATT&CK — আক্রমণকারীর কৌশল ও পদ্ধতির জ্ঞানভাণ্ডার; threat modeling ও detection-এ ব্যবহৃত হয়।

১৩৭. Lateral Movement — একটি সিস্টেমে ঢুকে নেটওয়ার্কের ভেতরে অন্য সিস্টেমে ছড়িয়ে পড়া; বিভাজন (segmentation) দিয়ে কমানো যায়।

১৩৮. Privilege Escalation — নিম্ন অনুমতি থেকে উচ্চ অনুমতি (যেমন admin) পেয়ে যাওয়া; least privilege দিয়ে প্রতিরোধ করা হয়।

১৩৯. Brute Force — সম্ভাব্য পাসওয়ার্ড একের পর এক চেষ্টা করা; rate limiting ও MFA দিয়ে ঠিক করা হয়।

১৪০. Phishing — ভুয়া ইমেইল বা বার্তা দিয়ে সিক্রেট বা অ্যাক্সেস হাতিয়ে নেওয়া; সচেতনতা ও MFA প্রতিরক্ষা দেয়।

১৪১. DDoS — Distributed Denial of Service; অনেক উৎস থেকে ট্রাফিক পাঠিয়ে সেবা অচল করা।

১৪২. Immutable Infrastructure — সার্ভার বদল না করে নতুন ইমেজ/সার্ভার দিয়ে প্রতিস্থাপন করা; ধারাবাহিকতা ও পুনরুৎপাদনযোগ্যতা বাড়ে।

১৪৩. Ephemeral Environment — অস্থায়ী পরিবেশ (যেমন PR-এর জন্য); কাজ শেষে মুছে ফেলা হয়।

১৪৪. Service Level — সেবার মানের প্রতিশ্রুতি; SLI দিয়ে মাপা হয়, SLO দিয়ে লক্ষ্য ঠিক করা হয়।

১৪৫. Availability — সেবা ব্যবহারযোগ্য থাকার অনুপাত; যেমন ৯৯.৯% মানে মাসে ~৪৩ মিনিট ডাউনটাইম অনুমোদিত।

১৪৬. Durability — ডেটা হারিয়ে না যাওয়ার নিশ্চয়তা; ব্যাকআপ ও replication দিয়ে বাড়ানো হয়।

১৪৭. Latency (p50/p95/p99) — রিকোয়েস্টের উত্তর দিতে কত সময় লাগে; p99 মানে ৯৯% রিকোয়েস্ট এই সময়ের মধ্যে শেষ হয়।

১৪৮. Tail Latency — সবচেয়ে ধীর রিকোয়েস্টগুলোর latency; গড় ভালো থাকলেও tail খারাপ হতে পারে।

১৪৯. Throughput — নির্দিষ্ট সময়ে কত কাজ শেষ হয়, যেমন প্রতি সেকেন্ডে রিকোয়েস্ট সংখ্যা।

১৫০. Saturation — রিসোর্স কতটা পূর্ণ; ১০০%-এর কাছাকাছি গেলে queue ও latency বাড়ে।

১৫১. Headroom — পিক লোডের জন্য রাখা অতিরিক্ত ধারণক্ষমতা; হঠাৎ ট্রাফিক সামলাতে সাহায্য করে।

১৫২. Connection Pool — ডেটাবেস সংযোগ পুনঃব্যবহারের ভাণ্ডার; শেষ হয়ে গেলে রিকোয়েস্ট আটকে যায়।

১৫৩. Caching — ঘন ঘন ব্যবহৃত ডেটা দ্রুত স্মৃতিতে রাখা; ডেটাবেসের চাপ কমায়।

১৫৪. CDN — Content Delivery Network; ব্যবহারকারীর কাছাকাছি সার্ভার থেকে কনটেন্ট দিয়ে latency কমায়।

১৫৫. Load Balancer — ট্রাফিক একাধিক সার্ভারে ভাগ করে দেওয়া; health check দিয়ে অসুস্থ সার্ভার সরিয়ে দেয়।

১৫৬. Health Check — সার্ভিস বেঁচে আছে ও কাজ করছে কি না তা নিয়মিত যাচাই করা।

১৫৭. Liveness Probe — Pod বেঁচে আছে কি না তা যাচাই; ব্যর্থ হলে Kubernetes Pod রিস্টার্ট করে।

১৫৮. Readiness Probe — Pod ট্রাফিক নিতে প্রস্তুত কি না তা যাচাই; প্রস্তুত না হলে ট্রাফিক সরানো হয়।

১৫৯. Horizontal Scaling — ইনস্ট্যান্সের সংখ্যা বাড়িয়ে ধারণক্ষমতা বাড়ানো।

১৬০. Vertical Scaling — একই ইনস্ট্যান্সের CPU/মেমোরি বাড়িয়ে ধারণক্ষমতা বাড়ানো।

১৬১. Multi-Region — একাধিক ভৌগোলিক অঞ্চলে সেবা চালানো; একটি অঞ্চল ব্যর্থ হলেও সেবা চালু থাকে।

১৬২. Active-Active — দুটি অঞ্চলই একসাথে ট্রাফিক নেয়; ফেইলওভার দ্রুত হয়, খরচ বেশি।

১৬৩. Active-Passive — একটি অঞ্চল সক্রিয়, অন্যটি প্রস্তুত থাকে; প্রয়োজনে ফেইলওভার করা হয়, খরচ কম।

১৬৪. Point-in-Time Recovery — নির্দিষ্ট সময়ের অবস্থায় ডেটাবেস ফিরিয়ে আনা; ভুল delete বা করাপশন থেকে রক্ষা করে।

১৬৫. Replication — ডেটার কপি একাধিক জায়গায় রাখা; প্রাপ্যতা ও পুনরুদ্ধারে সাহায্য করে।

১৬৬. Sharding — ডেটাকে ভাগ করে একাধিক ডেটাবেসে রাখা; বড় ডেটা সামলাতে ব্যবহৃত হয়।

১৬৭. Idempotency — একই অপারেশন বারবার করলেও ফল একই থাকে; retry নিরাপদ করে।

১৬৮. Backpressure — সিস্টেম চাপে থাকলে উৎসকে ধীরে কাজ করতে সংকেত দেওয়া; ধস এড়ানো যায়।

১৬৯. Graceful Degradation — আংশিক ব্যর্থতায় সেবা পুরো বন্ধ না হয়ে সীমিতভাবে চালু থাকা।

১৭০. Security Champion — প্রতিটি ডেভ টিমে নিরাপত্তা চর্চা ছড়িয়ে দেওয়ার দায়িত্বে থাকা সদস্য।

১৭১. Secure Code Review — কোড মার্জের আগে নিরাপত্তা দৃষ্টিতে পর্যালোচনা করা; SAST-এর পরিপূরক।

১৭২. Dependency Management — ব্যবহৃত লাইব্রেরির সংস্করণ, আপডেট ও ঝুঁকি পরিচালনা করা।

১৭৩. Vulnerability Triage — পাওয়া দুর্বলতাগুলো যাচাই করে শোষণযোগ্যতা ও প্রভাব অনুযায়ী সাজানো।

১৭৪. Compensating Control — মূল নিয়ন্ত্রণ না থাকলে তার বদলে অস্থায়ী বিকল্প নিয়ন্ত্রণ (যেমন WAF নিয়ম) দেওয়া।

১৭৫. Risk Acceptance — ঝুঁকি জেনে, নথিভুক্ত করে ও অনুমোদন নিয়ে তা গ্রহণ করা; অজান্তে উপেক্ষা করা নয়।

১৭৬. Cost Allocation — খরচ কোন টিম/প্রজেক্ট/সেবার জন্য হচ্ছে তা ভাগ করে দেখানো; tagging ছাড়া সম্ভব নয়।

১৭৭. Reserved / Committed Use — দীর্ঘমেয়াদে ব্যবহারের প্রতিশ্রুতি দিয়ে ক্লাউড খরচে ছাড় পাওয়া।

১৭৮. Spot / Preemptible Instance — অতিরিক্ত ধারণক্ষমতা সস্তায় ব্যবহার করা; যেকোনো সময় ফিরিয়ে নেওয়া যেতে পারে।

১৭৯. SLO Review — নিয়মিত SLO পর্যালোচনা করে লক্ষ্য এখনো ব্যবহারকারীর প্রত্যাশার সাথে মেলে কি না তা যাচাই করা।

১৮০. Continuous Improvement — প্রতিটি ইনসিডেন্ট ও পর্যালোচনা থেকে শিখে সিস্টেম ও প্রক্রিয়া ধীরে ধীরে ভালো করা; SRE ও DevSecOps-এর মূল চর্চা।

দ্রুত রেফারেন্স • কমান্ড

কমান্ড রেফারেন্স — নিরাপত্তা ও SRE টুল

সব কমান্ড শুধু **অনুমোদিত, আইসোলেটেড ল্যাব পরিবেশে** চালাবেন। কোনো বাস্তব সিক্রেট কমান্ডে লিখবেন না — `CHANGE-ME-...` প্লেসহোল্ডার ব্যবহার করুন।

১. নেটওয়ার্ক ও সিস্টেম পরীক্ষা

```
nmap -sV -p 1-1000 192.168.1.10
# খোলা পোর্ট ও সার্ভিসের সংস্করণ শনাক্ত করা (শুধু নিজের/অনুমোদিত হোস্টে)

ss -tulpn
# শোনা (listening) TCP/UDP পোর্ট ও প্রসেস দেখা

lynis audit system
# সিস্টেমের নিরাপত্তা নিরীক্ষা (audit) চালানো

sudo lsof -i -P -n | grep LISTEN
# কোন প্রসেস কোন পোর্টে শুনছে তা দেখা
```

২. কোড ও ডিপেন্ডেন্সি স্ক্যান

```
semgrep --config auto .
# সোর্স কোডে নিরাপত্তা দুর্বলতা স্ক্যান করা

trivy fs --severity HIGH,CRITICAL .
# ফাইলসিস্টেম/প্রজেক্টে CVE স্ক্যান করা

trivy image myapp:1.2.3
# কনটেইনার ইমেজে CVE স্ক্যান করা

grype myapp:1.2.3
# ইমেজে দুর্বলতা খোঁজা (Trivy-র বিকল্প)

syft myapp:1.2.3 -o cyclonedx-json > sbom.json
# ইমেজ থেকে SBOM তৈরি করা

npm audit --audit-level=high
# Node.js ডিপেন্ডেন্সিতে জানা CVE দেখা

pip-audit
# Python ডিপেন্ডেন্সিতে CVE দেখা
```

৩. স্বাক্ষর ও যাচাই

```
cosign sign --key cosign.key myregistry.example.com/myapp:1.2.3
# ইমেজ স্বাক্ষর করা (প্রাইভেট কি নিরাপদে রাখুন)

cosign verify --key cosign.pub myregistry.example.com/myapp:1.2.3
# স্বাক্ষর যাচাই করা
```

```
cosign verify --certificate-identity user@example.com \
  --certificate-oidc-issuer https://token.actions.githubusercontent.com \
  myregistry.example.com/myapp:1.2.3
# কীলেস (keyless) স্বাক্ষর যাচাই করা
```

৪. Kubernetes ও Helm

```
kubectl get pods -A
# সব Namespace-এর Pod দেখা

kubectl describe pod myapp-abc123 -n production
# Pod-এর বিস্তারিত অবস্থা ও ইভেন্ট দেখা

kubectl logs -f deployment/myapp -n production
# ডেপ্লয়মেন্টের লগ সরাসরি (follow) দেখা

kubectl top pods -n production
# Pod-এর CPU/মেমোরি ব্যবহার দেখা

kubectl auth can-i create pods -n production --as=developer
# একজন ব্যবহারকারী কী করতে পারে তা যাচাই করা

kubectl get networkpolicy -A
# NetworkPolicy-র তালিকা দেখা

helm lint ./mychart
# Helm চার্টের ভুল ধরা

helm template ./mychart --values values.yaml | kubeval
# রেন্ডার করা manifest যাচাই করা

helm upgrade --install myapp ./mychart -n production --atomic
# ব্যর্থ হলে স্বয়ংক্রিয় রোলব্যাকসহ আপগ্রেড করা
```

৫. Policy as Code

```
conftest test deployment.yaml -p policy/
# OPA/Rego নীতির বিরুদ্ধে manifest যাচাই করা

opa test policy/ -v
# Rego নীতির ইউনিট টেস্ট চালানো

checkov -d terraform/
# Terraform কোডে ভুল কনফিগারেশন স্ক্যান করা

tfsec terraform/
# Terraform-এর নিরাপত্তা স্ক্যান (Checkov-এর বিকল্প)
```

৬. Prometheus, Alertmanager ও k6

```
promtool check config prometheus.yml
# Prometheus কনফিগের ভুল ধরা

promtool check rules rules.yml
# অ্যালার্ট/রেকর্ডিং নিয়ম যাচাই করা

amtool check-config alertmanager.yml
# Alertmanager কনফিগ যাচাই করা

amtool silence list
# বর্তমান silence-র তালিকা দেখা

curl -s http://localhost:9090/api/v1/query?query=up
# Prometheus-এ up মেট্রিক জিজ্ঞাসা করা

k6 run --vus 50 --duration 5m load-test.js
# ৫০ ভার্চুয়াল ইউজার দিয়ে ৫ মিনিট লোড টেস্ট চালানো
```

৭. TLS, সিক্রেট ও লগ

```
openssl s_client -connect example.com:443 -servername example.com | openssl x509 -noout -dates
# সার্টিফিকেটের মেয়াদ দেখা

openssl x509 -in cert.pem -noout -text | grep -A2 Validity
# সার্টিফিকেটের বিবরণ দেখা

vault kv get secret/myapp/db
# Vault থেকে সিক্রেট পড়া (অনুমোদিত অ্যাক্সেসে)

kubectl create secret generic myapp-secret \
  --from-literal=password=CHANGE-ME-STRONG-PASSWORD -n production
# Kubernetes Secret তৈরি করা (বাস্তব পাসওয়ার্ড নয়, প্লেসহোল্ডার)

journalctl -u myapp -f
# সিস্টেমড সার্ভিসের লগ সরাসরি দেখা
```

মনে রাখবেন: স্ক্যান টুলের আউটপুটে সব finding-ই সত্য নয় — false positive যাচাই করে ত্রিয়াজ করুন। আর কোনো টুলই নিরাপদ কোড, সঠিক কনফিগারেশন ও ভালো প্রক্রিয়ার বিকল্প নয়।

দ্রুত রেফারেন্স • ওয়ার্কফ্লো

ওয়ার্কফ্লো রেফারেন্স — পাইপলাইন, ইনসিডেন্ট, DR ও Error Budget

১. নিরাপদ CI/CD পাইপলাইনের ধাপ

1. **কোড ও PR:** IDE লিন্টার + সিক্রেট স্ক্যান (gitleaks/trufflehog) → কোড রিভিউ (নিরাপত্তা দৃষ্টিসহ)।
2. **বিল্ড:** SAST (Semgrep) + SCA (npm audit / pip-audit) + লাইসেন্স যাচাই → উচ্চ-আস্থার finding-এ ব্লক।
3. **ইমেজ:** Multi-stage, minimal বেস → Trivy/Grype স্ক্যান → SBOM (Syft) তৈরি → Cosign স্বাক্ষর।
4. **IaC ও Manifest:** Checkov/tfsec + Conftest/OPA নীতি যাচাই → স্বাক্ষর যাচাই (admission-এ)।
5. **ডেপ্লয়:** Canary/Blue-Green → স্বয়ংক্রিয় smoke test → মনিটরিং দেখে ধীরে ধীরে ট্রাফিক বাড়ানো।
6. **রানটাইম:** DAST (স্টেজিং/প্রোডাকশনে নিরাপদে), CSPM স্ক্যান, লগ/মেট্রিক/ট্রেস পর্যবেক্ষণ।
7. **প্রতিক্রিয়া:** নতুন CVE এলে SBOM দিয়ে প্রভাব নির্ণয় → প্যাচ → আবার স্ক্যান → ডেপ্লয়।

২. ইনসিডেন্ট রেসপন্স ওয়ার্কফ্লো

1. **শনাক্ত (Detect):** অ্যালার্ট/রিপোর্ট থেকে ইনসিডেন্ট ঘোষণা, SEV নির্ধারণ, Incident Commander নিয়োগ।
2. **যোগাযোগ (Communicate):** নির্দিষ্ট চ্যানেলে প্রভাব, কী করা হচ্ছে ও পরের আপডেটের সময় জানানো।
3. **সীমিত করা (Contain/Mitigate):** ব্যবহারকারীর ক্ষতি কমানো — রোলব্যাক, ট্রাফিক সরানো, ফিচার ফ্ল্যাগ বন্ধ করা।
4. **তদন্ত (Investigate):** লগ/মেট্রিক/ট্রেস দিয়ে কারণ খোঁজা; দোষ নয়, সিস্টেমের কারণ খোঁজা।
5. **পুনরুদ্ধার (Recover):** স্থায়ী সমাধান ডেপ্লয়, পর্যবেক্ষণ করে স্বাভাবিক অবস্থা নিশ্চিত করা।
6. **পর্যালোচনা (Review):** Blameless postmortem, action items (দায়িত্বপ্রাপ্ত ও সময়সীমাসহ), শিক্ষা নথিভুক্ত করা।

৩. Vulnerability Remediation ওয়ার্কফ্লো

1. **আবিষ্কার:** স্ক্যান (SAST/DAST/SCA/Trivy/CSPM) থেকে finding সংগ্রহ।
2. **ত্রিয়াজ:** False positive বাদ দেওয়া, reachability ও শোষণযোগ্যতা যাচাই, CVSS + প্রভাব দিয়ে সাজানো।
3. **অগ্রাধিকার:** Critical + শোষণযোগ্য + ইন্টারনেটে উন্মুক্ত — প্রথমে; বাকিগুলো সময়সীমাসহ পরিকল্পনায়।
4. **প্রতিকার:** প্যাচ/আপডেট/কনফিগ ঠিক করা; না পারলে compensating control (যেমন WAF নিয়ম) দেওয়া।
5. **যাচাই:** আবার স্ক্যান করে ঠিক হয়েছে কি না নিশ্চিত করা; টিকিট বন্ধ করা।
6. **শিক্ষা:** একই ধরনের ভুল আবার না হয় — নিয়ম, টেমপ্লেট বা পরীক্ষা যোগ করা।

৪. DR রানবুকের রূপরেখা

- **উদ্দেশ্য ও সুযোগ:** কোন সেবা, কোন অঞ্চল, RTO/RPO কত।
- **ভূমিকা:** DR লিড, যোগাযোগের দায়িত্বে কে, অনুমোদন কে দেবে।
- **ট্রিগার:** কখন DR ঘোষণা করা হবে (যেমন প্রাইমারি অঞ্চল ১৫ মিনিট ধরে অনুপলব্ধ)।

- **ধাপ:** ১) প্রভাব যাচাই ২) ব্যাকআপ/replica যাচাই ৩) ফেইলওভার চালানো ৪) DNS/ট্রাফিক সরানো ৫) স্বাস্থ্য পরীক্ষা ৬) গ্রাহককে জানানো।
- **ফেইলব্যাক:** প্রাইমারি ঠিক হলে কীভাবে ফিরবেন — ডেটা সমন্বয়সহ।
- **পরীক্ষা:** প্রতি ত্রৈমাসিকে DR ড্রিল; ফলাফল নথিভুক্ত করা ও RTO/RPO যাচাই করা।

৫. Error Budget গণনার কাজের উদাহরণ

সূত্র: Error budget = (১০০% − SLO) × সময়কাল। ৩০ দিনের মাসে মোট সময় = ৩০ × ২৪ × ৬০ = ৪৩,২০০ মিনিট।

SLO	অনুমোদিত ব্যর্থতা	৩০ দিনের বাজেট
৯৯.৯%	০.১%	৪৩.২ মিনিট = ৪৩ মিনিট ১২ সেকেন্ড
৯৯.৯৯%	০.০১%	৪.৩২ মিনিট = ৪ মিনিট ১৯ সেকেন্ড
৯৯.৫%	০.৫%	২১৬ মিনিট = ৩ ঘণ্টা ৩৬ মিনিট
৯৯%	১%	৪৩২ মিনিট = ৭ ঘণ্টা ১২ মিনিট

> **৪ মিনিট ১৯ সেকেন্ড, ৪ মিনিট ২৩ সেকেন্ড নয় — কেন?** ৪৩,২০০ মিনিটের ০.০১% = ৪.৩২ মিনিট = ৪ মিনিট + ০.৩২ × ৬০ সেকেন্ড = ৪ মিনিট ১৯.২ সেকেন্ড ≈ **৪ মিনিট ১৯ সেকেন্ড**। ৪ মিনিট ২৩ সেকেন্ড আসে গড় মাস (৩০.৪৪ দিন) ধরে হিসাব করলে — ৩০.৪৪ × ১৪৪০ × ০.০০০১ ≈ ৪.৩৮ মিনিট। এই বইয়ে **৩০ দিনের মাস** ধরে হিসাব করা হয়েছে, তাই ৪ মিনিট ১৯ সেকেন্ডই সঠিক। হিসাবের সময়কাল (৩০ দিন নাকি গড় মাস) সবসময় স্পষ্ট করে লিখুন — নইলে দুটি সঠিক মনে হওয়া সংখ্যা মিলবে না।

কাজের উদাহরণ: একটি সেবার SLO ৯৯.৯%, ৩০ দিনের মাসে ৩০ মিনিট ডাউনটাইম হয়েছে। বাজেট ৪৩ মিনিট ১২ সেকেন্ড, খরচ ৩০ মিনিট — বাকি ১৩ মিনিট ১২ সেকেন্ড। বাজেট শেষ হওয়ার আগে সতর্ক হতে burn-rate অ্যালার্ট ব্যবহার করুন (যেমন ২ ঘণ্টায় ২% বাজেট খরচ হলে পেজ করুন)।

দ্রুত রেফারেন্স • চেকলিস্ট

চেকলিস্ট — OWASP, CI/CD, Kubernetes, IAM, SLO, ইনসিডেন্ট, FinOps ও প্রোডাকশন প্রস্তুতি

১. OWASP Top 10 দ্রুত রেফারেন্স (২০২১)

কোড	ঝুঁকি	মূল প্রতিকার
A01	Broken Access Control	সার্ভার-সাইডে deny-by-default অনুমোদন যাচাই
A02	Cryptographic Failures	শক্ত এনক্রিপশন, সঠিক কি ব্যবস্থাপনা, সংবেদনশীল ডেটা সুরক্ষা
A03	Injection	Parameterized query, ইনপুট যাচাই, আউটপুট এনকোডিং
A04	Insecure Design	ডিজাইন পর্যায়ে threat modeling
A05	Security Misconfiguration	নিরাপদ ডিফল্ট, অপ্রয়োজনীয় ফিচার বন্ধ, নিয়মিত পর্যালোচনা
A06	Vulnerable & Outdated Components	SCA, প্যাচিং, SBOM
A07	Identification & Authentication Failures	MFA, শক্ত পাসওয়ার্ড নীতি, ব্রুট-ফোর্স প্রতিরোধ
A08	Software & Data Integrity Failures	স্বাক্ষর যাচাই, CI/CD সুরক্ষা, SBOM
A09	Security Logging & Monitoring Failures	পর্যাপ্ত লগ, অ্যালার্ট, তদন্ত প্রক্রিয়া
A10	Server-Side Request Forgery (SSRF)	URL যাচাই, allowlist, নেটওয়ার্ক বিভাজন

২. নিরাপদ CI/CD চেকলিস্ট

- ☐ PR-এ SAST + SCA + সিক্রেট স্ক্যান চলে; উচ্চ-আস্থার finding-এ ব্লক হয়।
- ☐ ইমেজ স্ক্যান (Trivy/Grype) হয়; critical CVE-তে ডেপ্লয় আটকায় (বা নথিভুক্ত ঝুঁকি-গ্রহণ লাগে)।
- ☐ SBOM তৈরি ও সংরক্ষণ করা হয়; ইমেজ Cosign দিয়ে স্বাক্ষরিত।
- ☐ IaC ও manifest-এ Checkov/tfsec + Conftest/OPA যাচাই হয়।
- ☐ সিক্রেট মাস্কড ভেরিয়েবল বা secrets manager থেকে আসে; লগে দেখা যায় না।
- ☐ CI টোকেনে least privilege; PR-এর টোকেনে লেখার অনুমতি নেই।
- ☐ ডেপ্লয় Canary/Blue-Green-এ হয়; রোলব্যাক পরীক্ষিত।
- ☐ প্রতিটি ডেপ্লয়ে অডিট লগ থাকে — কে, কী, কখন ডেপ্লয় করেছে।

৩. Kubernetes নিরাপত্তা চেকলিস্ট

- ☐ Pod Security Standards (Restricted যেখানে সম্ভব) প্রয়োগ করা হয়েছে।
- ☐ runAsNonRoot, readOnlyRootFilesystem, allowPrivilegeEscalation: false দেওয়া হয়েছে।
- ☐ Resource request/limit সব Pod-এ দেওয়া হয়েছে।

- ☐ NetworkPolicy দিয়ে Pod-এর মধ্যে ট্রাফিক সীমিত করা হয়েছে।
- ☐ RBAC-এ least privilege; cluster-admin শুধু প্রয়োজনে।
- ☐ Secret external secrets manager থেকে আসে; etcd encryption at rest চালু।
- ☐ ইমেজ latest নয়, নির্দিষ্ট ট্যাগ/ডাইজেস্ট ব্যবহার করা হয়; স্বাক্ষর যাচাই হয়।
- ☐ Liveness ও readiness probe ঠিকভাবে কনফিগার করা হয়েছে।

৪. IAM ও সিক্রেট চেকলিস্ট

- ☐ Root অ্যাকাউন্ট দৈনন্দিন কাজে ব্যবহার করা হয় না; MFA চালু।
- ☐ প্রতিটি মানুষ ও সার্ভিসের আলাদা পরিচয়; ভাগ করা ক্রেডেনশিয়াল নেই।
- ☐ স্বল্পমেয়াদি ক্রেডেনশিয়াল; দীর্ঘমেয়াদি কি নিয়মিত rotate করা হয়।
- ☐ নিয়মিত অ্যাক্সেস রিভিউ হয়; চলে যাওয়া সদস্যের অ্যাক্সেস দ্রুত বন্ধ হয়।
- ☐ সিক্রেট গিটে নেই; সিক্রেট স্ক্যান চলে; ফাঁস হলে revoke প্রক্রিয়া জানা আছে।
- ☐ সংবেদনশীল ডেটা লগে মাস্ক করা হয়।

৫. SLI / SLO / SLA রেফারেন্স

ধারণা	অর্থ	উদাহরণ
SLI	পরিমাপ	সফল রিকোয়েস্টের অনুপাত ৯৯.৯৫%
SLO	লক্ষ্য	৩০ দিনে ৯৯.৯% রিকোয়েস্ট ৩০০ms-এর মধ্যে সফল হবে
SLA	চুক্তি	SLO না মানলে ১০% সার্ভিস ক্রেডিট
Error budget	অনুমোদিত ব্যর্থতা	৯৯.৯% SLO-তে ৩০ দিনে ৪৩ মিনিট ১২ সেকেন্ড

৬. ইনসিডেন্ট রেসপন্স চেকলিস্ট

- ☐ SEV নির্ধারণ করা হয়েছে; Incident Commander নিয়োগ করা হয়েছে।
- ☐ নির্দিষ্ট চ্যানেলে নিয়মিত আপডেট দেওয়া হচ্ছে (প্রভাব, কী করা হচ্ছে, পরের আপডেট কখন)।
- ☐ প্রশমন (mitigation) আগে, রুট কজ পরে — ব্যবহারকারীর ক্ষতি কমানো হয়েছে।
- ☐ প্রমাণ (লগ, স্ক্রিনশট, টাইমলাইন) সংরক্ষণ করা হচ্ছে।
- ☐ পুনরুদ্ধারের পর পর্যবেক্ষণ করে স্বাভাবিক অবস্থা নিশ্চিত করা হয়েছে।
- ☐ Blameless postmortem হয়েছে; action items-এ দায়িত্ব ও সময়সীমা আছে।

৭. FinOps চেকলিস্ট

- ☐ সব রিসোর্সে ট্যাগ আছে (টিম, প্রজেক্ট, পরিবেশ, মালিক)।
- ☐ মাসিক খরচের ভাঙন পর্যালোচনা করা হয়; হঠাৎ বৃদ্ধিতে অ্যালার্ট আছে।
- ☐ Idle/অতিরিক্ত বড় রিসোর্স right-size করা হয়েছে।
- ☐ অপ্রয়োজনীয় স্ন্যাপশট, পুরনো ব্যাকআপ ও অব্যবহৃত IP পরিষ্কার করা হয়।

- ☐ দীর্ঘমেয়াদি ব্যবহারে Reserved/Committed ছাড় বিবেচনা করা হয়েছে।
- ☐ ডেটা ট্রান্সফার ও স্টোরেজ খরচ পর্যবেক্ষণ করা হয়।

৮. প্রোডাকশন প্রস্তুতি (Readiness) চেকলিস্ট

- ☐ SLO ও অ্যালার্ট নির্ধারণ করা হয়েছে; burn-rate অ্যালার্ট আছে।
- ☐ Runbook আছে; on-call জানে কী করতে হবে।
- ☐ রোলব্যাক পরীক্ষা করা হয়েছে; ডেটাবেস মাইগ্রেশনে expand-contract অনুসরণ করা হয়েছে।
- ☐ ব্যাকআপ নেওয়া হয় ও restore পরীক্ষা করা হয়েছে।
- ☐ সিক্রেট, TLS মেয়াদ ও নির্ভরতার আপডেট পর্যবেক্ষণ করা হয়।
- ☐ লোড টেস্ট করা হয়েছে; ক্যাপাসিটিতে headroom আছে।
- ☐ নিরাপত্তা স্ক্যান (SAST/SCA/ইমেজ/IaC) পাস করেছে।
- ☐ DR ড্রিলের পরিকল্পনা আছে; RTO/RPO জানা আছে।

৯. নিরাপত্তা পর্যালোচনা টেমপ্লেট (Security Review Template)

সেবা: _____ **পর্যালোচক:** _____ **তারিখ:** _____

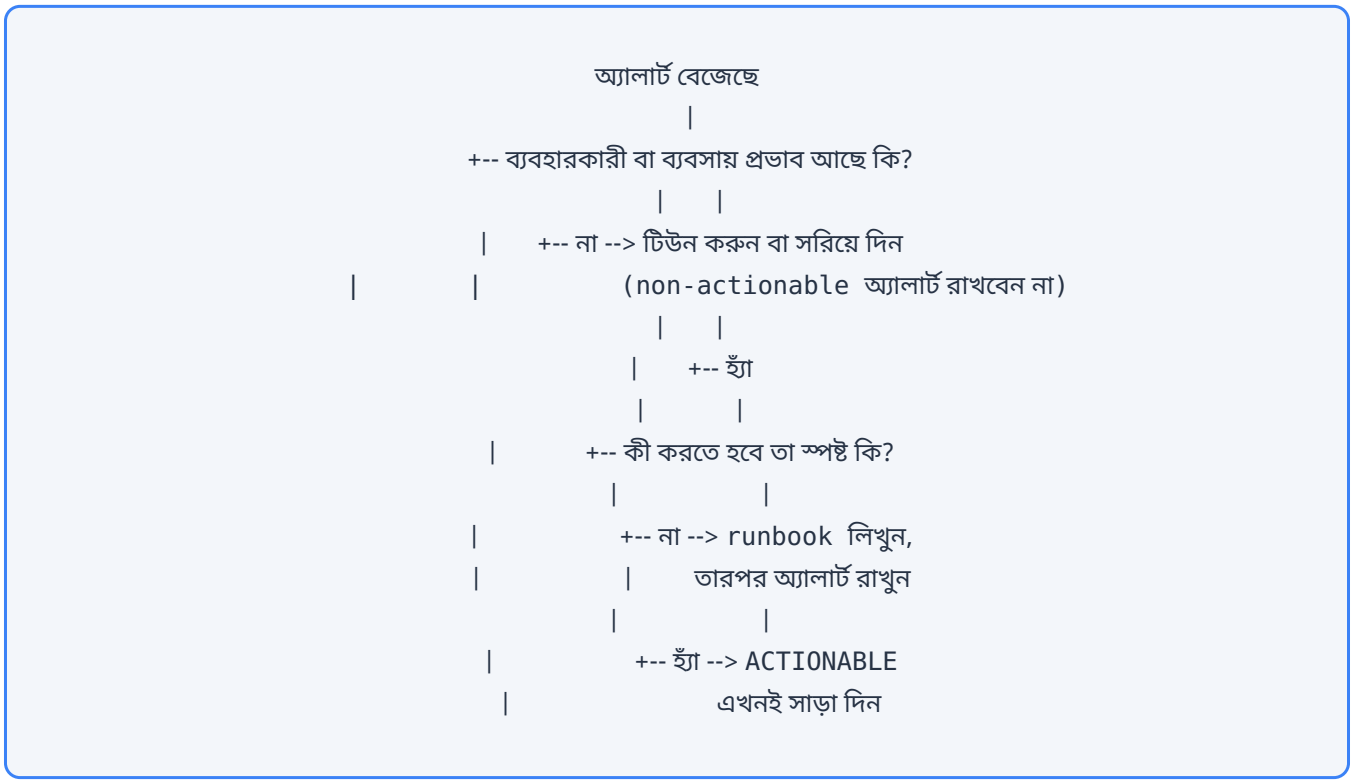
- **১. ডেটা:** কী সংবেদনশীল ডেটা আছে? কোথায় সংরক্ষিত ও কীভাবে এনক্রিপ্ট করা হয়?
- **২. অ্যাক্সেস:** কে কী অ্যাক্সেস করতে পারে? প্রমাণীকরণ ও অনুমোদন কীভাবে হয়?
- **৩. হুমকি:** প্রধান তিনটি হুমকি কী? প্রতিটির প্রতিরোধ কী?
- **৪. নির্ভরতা:** কোন থার্ড-পার্টি লাইব্রেরি/সার্ভিস ব্যবহৃত হয়? SBOM আছে কি?
- **৫. পাইপলাইন:** কোন স্ক্যান চলে? সিক্রেট কীভাবে পরিচালিত হয়?
- **৬. পর্যবেক্ষণ:** নিরাপত্তা ঘটনা কীভাবে ধরা পড়বে? লগ কতদিন রাখা হয়?
- **৭. পুনরুদ্ধার:** ব্যাকআপ ও DR পরিকল্পনা কী? শেষ পরীক্ষা কবে হয়েছিল?
- **৮. সিদ্ধান্ত:** ☐ অনুমোদিত ☐ শর্তসাপেক্ষে অনুমোদিত (শর্ত: _____) ☐ অনুমোদিত নয়

দ্রুত রেফারেন্স • ডিসিশন ট্রি

ট্রাবলশুটিং ডিসিশন ট্রি — ASCII ডায়াগ্রাম

নিচের প্রতিটি ডায়াগ্রামে ওপর থেকে নিচে প্রশ্নের উত্তর দিয়ে এগিয়ে যান।

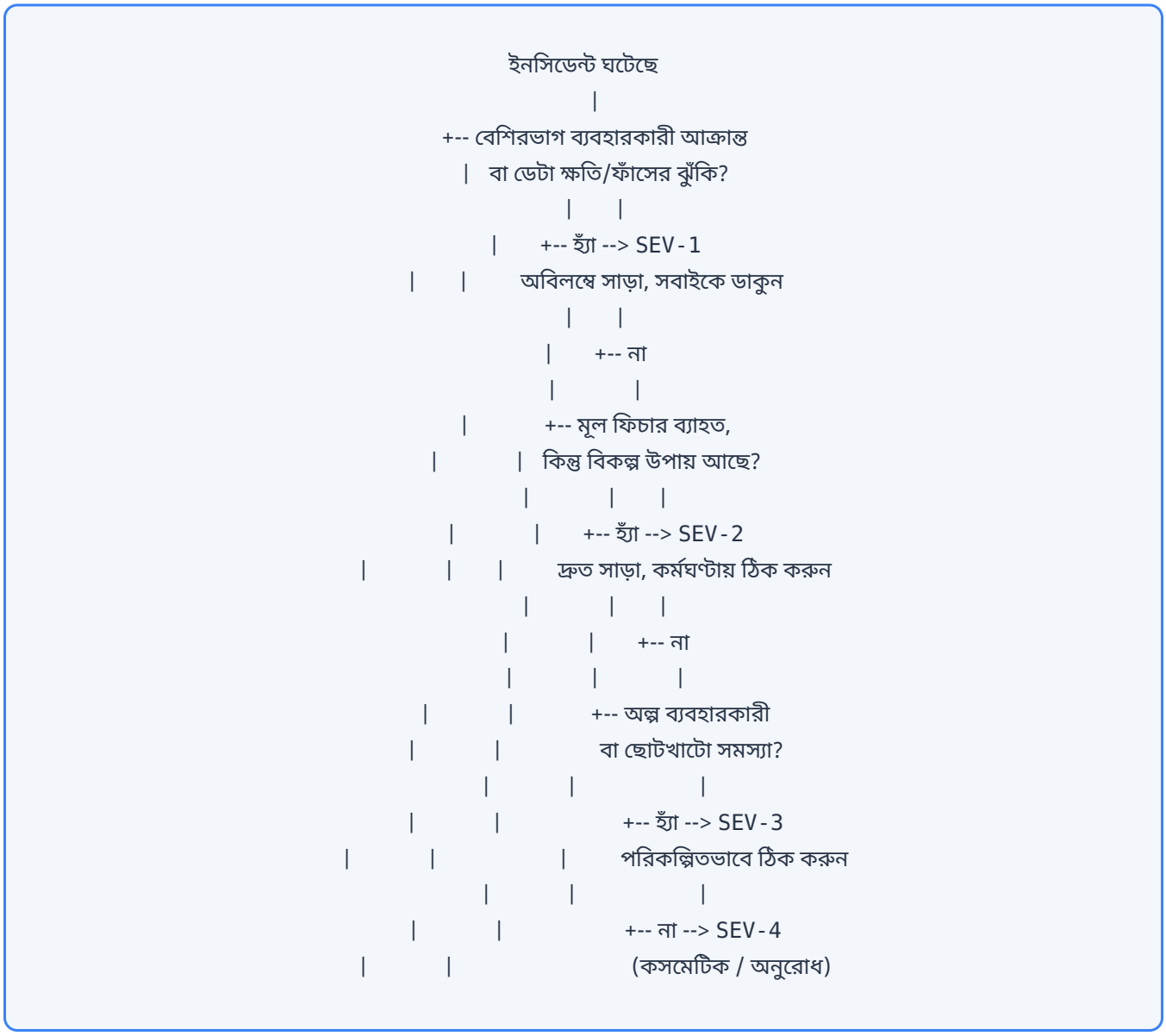
১. এই অ্যালার্টটি কি কার্যকর (actionable)?



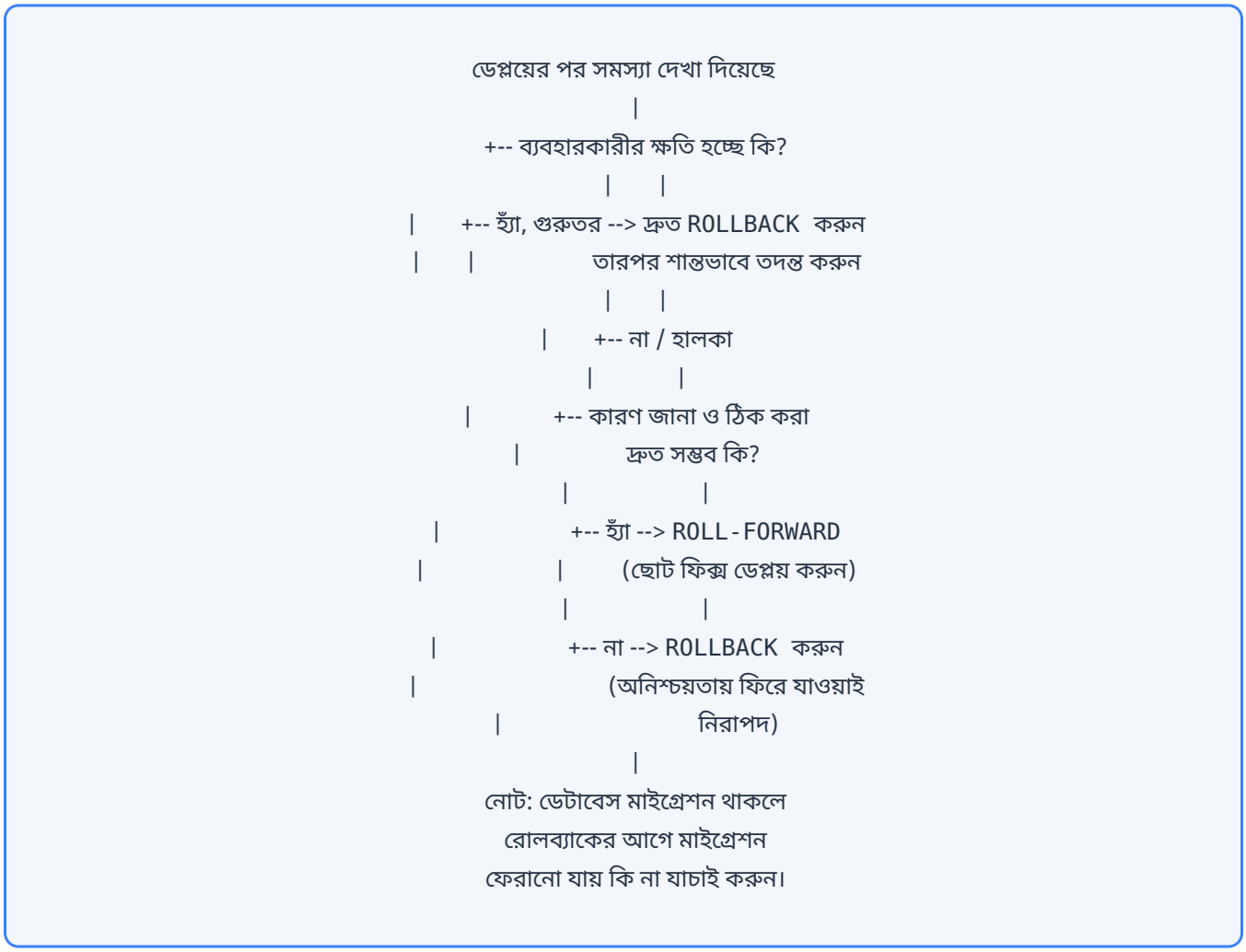
২. Vulnerability ত্রিয়াজ



৩. ইনসিডেন্ট তীব্রতা (Severity) শ্রেণিবিন্যাস



৪. রোলব্যাক নাকি রোল-ফরওয়ার্ড?



৫. ব্যাকআপ নাকি DR সক্রিয় করা?



নিজেকে যাচাই করুন • দক্ষতা ট্র্যাকিং

ব্যক্তিগত দক্ষতা (Competency) ট্র্যাকিং শিট

প্রতিটি দক্ষতায় নিজেকে রেটিং দিন: **১ = Beginner** (ধারণা জানি, সাহায্য লাগে), **২ = Intermediate** (স্বাধীনভাবে করতে পারি), **৩ = Advanced** (অন্যকে শেখাতে ও ডিজাইন করতে পারি)। প্রতি মাসে আপডেট করুন ও দুর্বল জায়গায় অনুশীলনের পরিকল্পনা লিখুন।

দক্ষতা	Beginner (১)	Intermediate (২)	Advanced (৩)	আমার রেটিং	পরের ধাপ
Threat modeling	☐	☐	☐		
OWASP Top 10 প্রতিকার	☐	☐	☐		
SAST / DAST / SCA ব্যবহার	☐	☐	☐		
কনটেইনার ও ইমেজ নিরাপত্তা (Trivy/Grype)	☐	☐	☐		
Kubernetes নিরাপত্তা (RBAC, NetworkPolicy, Pod Security)	☐	☐	☐		
SBOM ও SLSA	☐	☐	☐		
নিরাপদ CI/CD পাইপলাইন ডিজাইন	☐	☐	☐		
Policy as Code (OPA/Kyverno)	☐	☐	☐		
Vulnerability ত্রিয়াজ ও CVSS	☐	☐	☐		
ক্লাউড নিরাপত্তা (IAM, CSPM)	☐	☐	☐		
Secrets management (Vault)	☐	☐	☐		
SLI / SLO / Error budget	☐	☐	☐		
Prometheus / PromQL ও Grafana	☐	☐	☐		
Distributed tracing (OpenTelemetry)	☐	☐	☐		
অ্যালার্ট ডিজাইন (burn-rate)	☐	☐	☐		
Incident management ও blameless postmortem	☐	☐	☐		
Load / stress testing ও ক্যাপাসিটি প্ল্যানিং	☐	☐	☐		
DR পরিকল্পনা ও restore পরীক্ষা	☐	☐	☐		
Chaos engineering	☐	☐	☐		
FinOps ও খরচ অপ্টিমাইজেশন	☐	☐	☐		

আমার অগ্রাধিকার (পরের ৩০ দিনে): ১) _____ ২) _____ ৩) _____

অনুশীলন পরিকল্পনা: প্রতি সপ্তাহে একটি পরিস্থিতি সমাধান করব, একটি ল্যাব কাজ করব ও একটি কেস স্টাডি নিয়ে আলোচনা করব।

অফিসিয়াল রেফারেন্স

অফিসিয়াল রেফারেন্স

নিচে শুধু অফিসিয়াল ডকুমেন্টেশন হোমপেজ দেওয়া আছে। বিস্তারিত পাতার জন্য সাইটের ভেতরে খুঁজুন — গভীর URL অনুমান করে লেখা হয়নি।

১. নিরাপত্তা মান ও ফ্রেমওয়ার্ক

- OWASP — https://owasp.org/
- OWASP Top 10 — https://owasp.org/www-project-top-ten/
- NIST Cybersecurity Framework — https://www.nist.gov/cyberframework
- NIST Special Publications — https://csrc.nist.gov/publications
- MITRE ATT&CK — https://attack.mitre.org/
- CVE Program — https://www.cve.org/
- National Vulnerability Database (NVD) — https://nvd.nist.gov/

২. সাপ্লাই চেইন ও ক্লাউড-নেটিভ নিরাপত্তা

- SLSA — https://slsa.dev/
- Sigstore — https://www.sigstore.dev/
- OpenSSF — https://openssf.org/
- CNCF — https://www.cncf.io/
- CNCF Landscape — https://landscape.cncf.io/

৩. Kubernetes ও ক্লাউড-নেটিভ

- Kubernetes Documentation — https://kubernetes.io/docs/
- Helm — https://helm.sh/docs/
- Argo CD — https://argo-cd.readthedocs.io/
- Open Policy Agent — https://www.openpolicyagent.org/docs/
- Kyverno — https://kyverno.io/docs/

৪. পর্যবেক্ষণযোগ্যতা (Observability)

- OpenTelemetry — https://opentelemetry.io/docs/
- Prometheus — https://prometheus.io/docs/
- Grafana Documentation — https://grafana.com/docs/
- Jaeger — https://www.jaegertracing.io/docs/

৫. HashiCorp ও অবকাঠামো

- HashiCorp Developer (Terraform, Vault, Consul) — https://developer.hashicorp.com/
- Terraform Documentation — https://developer.hashicorp.com/terraform/docs
- Vault Documentation — https://developer.hashicorp.com/vault/docs

৬. ক্লাউড প্রদানকারী ডকুমেন্টেশন

- Amazon Web Services Documentation — https://docs.aws.amazon.com/
- Google Cloud Documentation — https://cloud.google.com/docs
- Microsoft Azure Documentation — https://learn.microsoft.com/azure/

৭. FinOps ও নির্ভরযোগ্যতা

- FinOps Foundation — https://www.finops.org/
- Google SRE Books — https://sre.google/books/
- Site Reliability Engineering (Google) — https://sre.google/sre-book/table-of-contents/

> **আরও পড়া:** উপরের প্রতিটি সাইটে "Getting Started" ও "Best Practices" পাতা থেকে শুরু করুন। বইয়ের অধ্যায়গুলোতে যেসব টুলের নাম এসেছে (Trivy, Grype, Semgrep, Checkov, k6), সেগুলোর অফিসিয়াল ডকুমেন্টেশন সংশ্লিষ্ট প্রকল্পের হোমপেজ থেকে খুঁজে নিন।

— Assessment & Quick Reference Companion, Volume 15 — সমাপ্ত —